

NATIONAL BANKING AUTHORITY

NBA/DOR/2026-27/118

December 20, 2026

National Banking Authority (Digital Payment Security Controls)
Directions, 2026

Chapter I — Preliminary

1. Short Title and Commencement: These Directions shall be called the National Banking Authority (Digital Payment Security Controls) Directions, 2026, and shall come into force with effect from April 1, 2027.

2. Applicability: These Directions apply to every regulated entity offering digital payment services, including mobile banking, internet banking, and card-based payment channels.

3. Definitions

(i) 'Multi-Factor Authentication' means an authentication mechanism requiring the presentation of two or more independent categories of credentials.

(ii) 'Data Breach' means the unauthorized acquisition of customer financial information that compromises the security, confidentiality, or integrity of such information.

(iii) 'Critical Incident' means an event that disrupts, or has the potential to disrupt, core banking operations or compromise customer data.

(iv) 'Device Binding' means the association of a customer's registered credentials with a specific physical device to prevent unauthorized access from unrecognized devices.

(v) 'Payment Gateway' means a third-party service that authorizes and processes payment transactions between a customer, a merchant, and the regulated entity.

(vi) 'Tokenization' means the process of replacing sensitive card data with a unique, non-sensitive token that has no exploitable value if intercepted.

(vii) 'Security Operations Center (SOC)' means the function responsible for continuous monitoring and analysis of an entity's security posture.

(viii) 'Zero-Day Vulnerability' means a previously unknown software or system flaw that has not yet been patched by the vendor.

Chapter II — Authentication and Access Controls

4. Every regulated entity offering digital payment services shall implement multi-factor authentication for all customer-initiated transactions exceeding \$5,000, comprising at least two independent authentication factors.

5. Regulated entities shall not store customer card verification values (CVV), one-time passwords (OTP), or PINs in plain text under any circumstances. All such data shall be encrypted using industry-standard cryptographic algorithms.

6. Session timeouts for digital banking applications shall not exceed 10 minutes of inactivity, after which re-authentication shall be mandatory.

7. Regulated entities shall implement device binding for mobile banking applications, restricting a registered credential to a maximum of two active devices at any time.

Explanation: For the purposes of clause 4, transactions below ■5,000 may use single-factor authentication only where the cumulative value of such transactions in a rolling 24-hour window does not exceed ■25,000.

Explanation: For the purposes of clause 5, 'industry-standard cryptographic algorithms' means encryption meeting or exceeding AES-256 for data at rest and TLS 1.2 or higher for data in transit.

Chapter III — Incident Response and Breach Notification

8. Regulated entities shall classify security incidents by severity and shall adhere to the reporting timelines set out in Annexure I.

9. Regulated entities shall conduct a comprehensive cybersecurity risk assessment at least once annually, and the results shall be placed before the Board of Directors or its designated committee.

Severity	Description	Reporting Deadline
Critical	Core banking system compromise; large-scale customer data exposure	6 hours from detection
High	Breach affecting fewer than 10,000 customer records	24 hours from detection
Medium	Attempted intrusion, contained without data loss	7 days (consolidated report)
Low	Minor policy violations, no customer impact	Quarterly consolidated report

10. The regulated entity shall notify affected customers of a confirmed Critical or High severity data breach within 72 hours of detection, and shall provide clear guidance on remedial steps the customer should take.

11. Any unauthorized access to core banking systems shall be treated as a Critical Incident and shall be escalated to the Chief Information Security Officer within 30 minutes of detection.

Chapter IV — Vendor and Third-Party Payment Gateway Controls

12. Regulated entities shall conduct security audits of third-party payment gateway providers at least once every twelve months, and shall not process transactions through providers who have not undergone such an audit.

13. Contracts with third-party payment processors shall include explicit data protection clauses consistent with these Directions, and shall be reviewed by the compliance function prior to execution.

Chapter V — Board and Senior Management Responsibilities

14. The Board of Directors shall approve a comprehensive Cyber Security Policy, distinct from the entity's general IT policy, and shall review it at least once every year.

15. The regulated entity shall designate a Chief Information Security Officer (CISO), reporting functionally to the Risk Management Committee of the Board, responsible for implementation of these Directions.

16. The CISO shall submit a quarterly report to the Board on the entity's cybersecurity posture, including all Critical and High severity incidents recorded in the quarter.

Chapter VI — Transitional Provisions

17. Regulated entities shall achieve full compliance with the multi-factor authentication requirements under Chapter II within twelve months of the commencement date.

18. Guidance notes issued by the Authority on digital payment security prior to these Directions stand repealed with effect from the commencement date.

Chapter VII — Record Keeping and Penalties

19. Logs of all authentication attempts, security incidents, and remedial actions shall be retained for a minimum of five years and made available to the Authority upon request.

20. Failure to report a Critical or High severity incident within the prescribed timeline shall attract a monetary penalty and shall be escalated to the Board of the regulated entity.

(S. Chakraborty)
Chief General Manager